TUT3_P410_4PM_6PM_GROUP-6

GROUP MEMBERS	-	STUDENT NUMBERS
Manoj Godavarthi	-	[redacted]
Srinivasa Teja Bharadwaj Penumudi	-	[redacted]
Lokesh Kunapaneni	-	[redacted]

MANOJ GODAVARTHI
SRINIVASA TEJA BHARADWAJ P
LOKESH KUNAPANENI

TABLE OF CONTENTS:

Introduction----------2

Risk Management Plan----------3

Risk Priority Table----------4

TV pairs mitigation strategies and ACC overviews----------5-7

Cost Benefit Analysis Table----------8-9

Explanation And Justification----------9-10

Group Reflection----------11

Individual Reflection----------12

References----------13

MANOJ GODAVARTHI
SRINIVASA TEJA BHARADWAJ P
LOKESH KUNAPANENI

INTRODUCTION:

CyberGenesis stands at the forefront of the cybersecurity realm, fueled by the inspiring ethos, "Where Security Meets Innovation." Our mission is to empower businesses with cutting-edge protective measures—from rigorous penetration testing to robust cloud security and effective threat mitigation—ensuring that our clients are always a step ahead in a rapidly shifting threat landscape.

Among our valued partners is **LearnX**, a forward-thinking, **medium-sized EduTech enterprise** headquartered in the dynamic city of **Sydney, Australia**. With a dedicated team of around **200 employees**, LearnX pioneers the digital education space through its sophisticated **Learning Management System (LMS)**. The platform delivers a rich suite of services, including **curated online courses**, **virtual classrooms**, **interactive testing**, **certificate tracking**, and **seamless third-party learning integrations**.

LearnX operates through strategically placed branches in:

📍 **Melbourne**, where the **IT and Technology Division** leads platform development and technical innovation

📍 **Brisbane**, which manages **customer service**, **compliance**, and all **regulatory support functions**

To protect its digital infrastructure, LearnX has built a strong cybersecurity framework led by an experienced Chief Information Security Officer (CISO). The team includes a proactive Security Operations Center (SOC), cloud and network security engineers, application security analysts, digital forensics experts, and dedicated staff focused on privacy and user awareness.

Critical Information Assets Secured by LearnX Include:Student & Customer Data: Protected in full compliance with **GDPR** and the **Australian Privacy Act**, including academic records and personal identifiers

Financial Data: Secure payment transactions, encrypted and monitored for fraud protection

Authentication Systems & User Credentials: Protected through **OAuth 2.0**, token security, and **multi-factor authentication (MFA)**

API Integrations & Third-Party Tools: Defended with secure gateways, rate-limiting, and strict API access control

Business Intelligence & Reports: Sensitive analytics and IP restricted via access policies and encryption

- **Complaint Records & Audit Trails:** Secured for governance, legal defense, and operational transparencyThrough this strategic alliance, **CyberGenesis and LearnX** combine deep cybersecurity expertise with educational excellence — forging a strong, adaptable security framework that protects platforms, data, and learners in a rapidly changing digital world

Threat	Threat Agent	Asset Staff	Asset Value	EF, ARO	Vulnerability	Exploit	Organisational risk impact (H,M,L)	Mitigation	Justification	Annualised control cost
Unpatched Software Vulnerability	Technical, unintentional	Learning Management System (LMS)	$2.45 mil	60%, 2/year	Outdated LMS plugin with known CVE	Exploit used to gain admin access or run malicious code	High	Regular patching and automated vulnerability scans	Prevents attackers from exploiting outdated code	$45,000
Cloud Exposure	Human, Unintentional	Azure storage bucket with client project data	$1.25 mil	50%, 1/year	Publicly accessible misconfigured storage bucket	Unauthenticated user accesses exposed files from misconfigured cloud container	Medium	Enforce strict access policies and cloud config audits	Prevents unauthorized access to sensitive cloud data	$38,000
Ransomware (Software)	Human, Intentional	Workstations and Shared drives	$600,000	40%, 3/year	Email filtering not enforced, no EDR	User opens attachment (containing ransomware) from unknown e-mail	Medium	Install up-to-date internet security software	Detects malware and prevents installation	$35,000
Power Outage	Environmental, Unintentional	LMS Hosting server (if on premises or	$150,000	60%, 2/year	Unstable power grid (or) location in an area suspect	Hypothetical, many universities might shut down	Medium	Cloud-based LMS backup	Maintains availability during outages	$6,000 - $8,000

		hybrid)			able to flood	during storms				

RISK PRIORITY TABLE:

TV pair (from section 1)	Likelihood (0-100)	Impact (0 -1)	Risk Value	Risk Impact	YES OR NO? Does the Risk Impact match the Organisational Impact (H,M,L) from Section 1? If No, why not?
TV 1 (Software Vulnerability)	77	0.8	61.6	Normal	No (Risk impact to the firm is high because once someone gains access to the administration they can run malicious code or can breach through network and can access other too that is why its high)
TV 2 (Cloud Exposure)	60	0.9	54	Normal	yes
TV 3 (Ransomware)	79	0.8	63.2	Normal	yes
TV 4 (Environmental)	75	0.9	67.5	Normal	yes

MANOJ GODAVARTHI
SRINIVASA TEJA BHARADWAJ P
LOKESH KUNAPANENI

TV pairs mitigation strategies and ACC overviews:

TV pair 1: In a mid-sized educational institution with approximately 10,000 students, a cybersecurity incident stemming from unpatched software can lead to severe financial and operational consequences. The average cost per compromised student record is about $245, meaning a breach could cost around $2.45 million, factoring in investigation, remediation, legal fees, fines, and notifications. Detection and containment often take over 300 days, further increasing costs due to extended downtime. The reputational damage can erode student trust, impact enrollment, and threaten funding. If sensitive data, like medical records or grades, is involved, the institution may face legal ramifications under laws such as FERPA or GDPR. Investing in robust cybersecurity measures, including vulnerability scanning, patching, staff training, and incident response plans, is crucial to avoid these costly outcomes.

ACC breakdown for TV pair 1:

1. **Patch Management System:** Automates deployment of critical updates to systems and applications.
   ACC: $7,800/year (Licensing for tools like Microsoft Intune, ManageEngine, or Ivanti)
2. **Vulnerability Scanning:** Continuously identifies known vulnerabilities in operating systems, applications, and infrastructure.
   ACC: $3,000–$6,500/year (Tools such as Tenable, Qualys, or OpenVAS)
3. **Patch Testing Environment:** Enables safe pre-deployment testing of updates to prevent system disruptions.
   ACC: $3,600–$4,600/year (Virtual labs or cloud-based sandbox environments)
4. **IT Staff Training:** Builds team capability in deploying patches effectively and responding to patch-related incidents.
   ACC: $4,000–$4,500/year (Hands-on and awareness training for IT/security staff)
5. **Documentation & Audit Readiness:** Maintains patch records and supports compliance with ISO 27001, SOC 2, and NIST.
   ACC: $1,500–$2,200/year (Maintaining logs, changelogs, audit documentation)

   Total Estimated Cost: $45,000/year

TV pair 2: A medium-sized EduTech organization with around 10,000 student records values its data at about $1.25 million. This amount reflects risks associated with sensitive student information, including personal details and academic records. The main component is personally identifiable information (PII), such as names and contact details, valued at $75 per record, totaling $750,000. This aligns with industry standards from IBM's Cost of a Data Breach Report (2023), which indicates that breaches involving student records can be costly. The academic data linked to learning management systems, like grades and attendance, adds

another $250,000 at $25 per record. The organization allocates $150,000 for reputational and legal risks due to strict data protection laws, as well as a $100,000 buffer for potential fines. This valuation is supported by incidents like the 2022 Illuminate Education breach, which affected over 3 million students and resulted in significant legal issues, underscoring the need for strong data protection. (This was considered particularly for the bucket of student data because the following references talk about a similar incident)

ACC breakdown for TV pair 2:

1. **Access Control & SAS Token Hardening** – Prevents unauthorized access through misconfigured or over-permissioned Shared Access Signatures (SAS).
   ACC: $4,000/year (Includes Azure Policy configuration, key rotation automation, and internal IT time)
2. **Azure Monitoring & Alerting (Microsoft Defender for Storage)** – Detects unusual blob access, suspicious traffic, or misconfigurations in real-time.
   ACC: $6,000/year (Includes $0.02 per 10K transactions/month + alert tuning and setup)
3. **Azure Policy & Blueprints** – Prevents public exposure of storage buckets and ensures misconfigurations are blocked at deployment.
   ACC: $3,000/year (Covers IT governance time and 2–3 policy audits per year)
4. **Security Awareness Training (SAT) – DevOps & Engineering** – Educates technical staff on secure storage handling and avoiding key leaks (e.g., on GitHub).
   ACC: $5,000/year (Targeted training for ~50 staff using KnowBe4 or equivalent)
5. **Data Loss Prevention (DLP) – Microsoft Purview** – Prevents unauthorized file sharing via sensitivity labels, auto-encryption, and policy enforcement.
   ACC: $8,000/year (Microsoft Purview license and monitoring)
6. **External Penetration Testing (Cloud + App Layer)** – Identifies vulnerabilities in public cloud endpoints and misconfigured storage.
   ACC: $12,000/year (Annual third-party cloud-focused pen testing

TV pair 3: The asset valuation of $600,000 for a ransomware attack accurately reflects the financial impact on a medium-sized EduTech company. This assessment includes around 100 employee workstations, each valued between $1,000 and $1,500, totaling more than $120,000. Additionally, the potential compromise of networked resources and proprietary data, including LMS configurations, student records, and internal documents, is estimated to be between $150,000 and $200,000. Furthermore, the productivity loss from a 5-day downtime, calculated at $200 per employee per day, results in an additional loss of $100,000. When combined, these factors bring the total estimated asset exposure to $600,000.

ACC breakdown for TV pair 3:

1. **Multi-Factor Authentication (MFA)** – Prevents unauthorized access from stolen credentials.
   ACC: $9,200/year (MFA cisco duo- 3$ per license)

2. **Email Filtering & Malware Sandboxing** – Blocks phishing emails and malicious 5attachments.
   ACC: $9,200/year (email filtering protection – Microsoft defender – 3$ licenses)
3. **Security Awareness Training (SAT)** – Educates staff to avoid phishing and risky behavior.
   ACC: $7,000/year
4. **Automated Backup & Recovery** – Ensures critical data can be restored without ransom.
   ACC: $7,000/year (Acronis licensing approx. 2000$ per year for 200 end points and specific team's time)

These are for a ransomware attack ACC in a medium sized EduTech company.

TV pair 4: In the event of a natural disaster like a cyclone, LearnX's Learning Management System (LMS) can be at risk due to power outages and inaccessibility. This system is crucial for supporting thousands of students with online courses, assessments, and learning records. It is valued at about $150,000, which includes the cost of servers, storage systems, networking equipment, licensed software, labor for installation, and support systems like cooling and power. If this system becomes inoperable, LearnX could face significant financial losses from service downtime, violations of service level agreements, and harm to its reputation. To prevent this, it is essential to have cloud failover and disaster recovery solutions in place to protect revenue and maintain trust.

ACC breakdown for TV pair 4:

1. **Cloud-Based LMS Failover Hosting:** Ensures uninterrupted access to the LMS during power outages or natural disasters.
   ACC: $3,500/year (Includes backup hosting on AWS/Azure with sync capabilities and minimal reserved compute usage)

2. **Automated Backup & Data Syncing:** Maintains regular encrypted backups of critical systems and course data.
   ACC: $1,200/year (Veeam or Acronis for nightly backups and syncing to cloud storage)

3. **Disaster Recovery Testing & Documentation:** Validates disaster preparedness through annual simulations and updated DR runbooks.
   ACC: $1,000/year (Tabletop exercises, policy reviews, and technical recovery validation)

4. **Disaster Response Training (IT & Support Staff):** Equips staff to respond quickly to infrastructure failures and initiate failover.
   ACC: $800/year (Annual incident simulation and role-based response training)

Total Estimated Cost: $6,500/year.

MANOJ GODAVARTHI
SRINIVASA TEJA BHARADWAJ P
LOKESH KUNAPANENI

COST BENEFIT ANALYSIS TABLE:

No Limited Budget:

Analysis & Recommendations b)

TV Pair	Asset	Asset Valuation	Exposure Factor	Single Loss Expectancy	Annual Rate of Occurrence (pre-control)	Annualized Loss Expectancy (pre control)	Annualized Control Cost	Annual Rate of Occurrence (post-control)	Annualized Loss Expectancy (post control)	Cost Benefit Analysis
		AV	EF	SLE = AV * EF	ARO	ALE=SLE*ARO	ACC	ARO_1	$ALE=SLE*ARO_1$	$CBA=ALE_{pre} - ALE_{post} - ACC$
1	Software	20,45,000	60%	12,27,000	2	24,54,000	45,000	1	12,27,000	11,82,000
2	Client In formation & Data	10,25,000	50%	5,12,500	1	5,12,500	38,000	0.5	2,56,250	2,18,250
3	Employee Computers	6,00,000	40%	2,40,000	3	7,20,000	35,000	1	2,40,000	4,45,000
4	Acess to servers	1,50,000	60%	90,000	1	90,000	6,500	0.5	45,000	38,500
						Total Control Cost	1,24,500			**18,45,250**
						Budget Constraint	N/A			

Limited Budget Constraint:

Analysis & Recommendations b)

TV Pair	Asset	Asset Valuation	Exposure Factor	Single Loss Expectancy	Annual Rate of Occurrence (pre-control)	Annualized Loss Expectancy (pre control)	Annualized Control Cost	Annual Rate of Occurrence (post-control)	Annualized Loss Expectancy (post control)	Cost Benefit Analysis
		AV	EF	SLE = AV * EF	ARO	ALE=SLE*ARO	ACC	ARO_1	$ALE=SLE*ARO_1$	$CBA=ALE_{pre} - ALE_{post} - ACC$
1	Employee training and awareness	24,00,000	60%	12,27,000	2	24,54,000	7,000	1.8	22,08,600	2,38,400
2	Access Control and SAS token hardening	10,25,000	20%	2,05,000	1	2,05,000	4,000	0.8	1,64,000	37,000
3	Email filtering and malware sandboxing	6,00,000	40%	2,40,000	3	7,20,000	9,200	2.5	6,00,000	1,10,800
4	Automated backup or data syncing	1,50,000	60%	90,000	1	90,000	1,200	0.7	63,000	25,800
						Total Control Cost	21,400			3,86,200
						Budget Constraint	16,050			

Explanation And Justification:

TV Pair 1 - Employee Training and Awareness:

The key focus is on the human element—specifically, employee training and awareness. In today's cyber landscape, human error is the most exploited vulnerability. For an EduTech company like LearnX, where staff interact with cloud platforms and handle sensitive data, risks from accidental clicks or poor password practices are high.

Training helps employees recognize and prevent social engineering threats, turning them into active lines of defense against phishing and data mishandling. Since most cyberattacks, such as ransomware and credential theft, are triggered by avoidable human mistakes, this training is essential. Ultimately, equipping staff to think critically and securely is a valuable investment that enhances the effectiveness of all cybersecurity measures.

TV Pair 2 - Access Control and SAS Token Hardening:

The second focus is on securing LearnX's cloud infrastructure through effective access controls and proper management of Shared Access Signatures (SAS). This is crucial for EduTech organizations like LearnX that rely on platforms such as Microsoft Azure to store sensitive data. Misconfigured SAS tokens can inadvertently expose large amounts of information, as demonstrated by Microsoft's 2023 incident where 38TB of internal files were compromised due to overly permissive tokens. By addressing this issue, we aim to reduce the risk of unauthorized access to cloud-stored information and support our implementation of zero-trust principles across the organization's infrastructure.

TV Pair 3 - Email Filtering and Malware Sandboxing:

This asset focuses on improving email security. Email is a common target for attacks like phishing and harmful attachments. LearnX, which operates in multiple cities, needs to protect its email communication. Using advanced email filtering and malware sandboxing helps reduce the risk of phishing attacks. This approach tests attachments and links in a safe environment before users access them. In the EduTech sector, where staff and students often share files, securing email is crucial. It effectively stops threats before reaching users and offers good value for the cost, despite being more expensive.

TV Pair 4 - Automated Backup and Data Syncing:

This asset highlights resilience through automated backups and continuous syncing. LearnX relies on its Learning Management System (LMS) for course content, assessments, and user records. Disruptions—whether from ransomware, server crashes, or natural disasters—can halt learning and harm the company's reputation. The focus here is on recovery rather than prevention. Backups act as a safety net, enabling quick resumption of operations and reducing the risk of ransoms and outages. This cost-effective solution ensures business continuity, as downtime is a critical failure that affects thousands of users.

We ended up slightly over budget $21,400 compared to the limit of $16,050, but it was a smart decision. The extra $5,350 was invested in two critical areas: employee training and email filtering. These measures directly address the most common ways attacks occur through human error and phishing emails and they provide significant risk reduction.

While we could have remained within budget, doing so would have left LearnX vulnerable to much larger issues. Spending a bit more now helps us avoid incidents that could cost the company lakhs, or even damage its reputation. So yes, we overspent, but we did it for the right reasons: to protect what matters most right now.

GROUP REFLECTION:

This report formed through a systematic process executed with collective work that prioritized both technical precision and risk assessments and financial evidence. The work followed a systematic breakdown into research activities which led to analysis tasks and then moved into priority setting tasks before proceeding to justification steps and concluding with report preparation. Assessment sessions prompted leader decisions to distribute responsibilities so control analysis and risk modelling tasks went to technical experts alongside duties for documentation and content simplification and formatting conducted by other members.

The main success factor of our work involved determining which threats appeared most often in operational cloud environments. Each risk received practical and authentic support through examples taken from actual well-known events to establish realistic and applicable recommendations. Our approach for controlling risk identification involved selecting important threats first so that we could apply budget management to establish control deployments according to their criticality.

What worked well:

Each team member received tasks that maximized their own abilities leading to coherent collaborative work.

The team made joint decisions while budgeting decisions through impact assessment and likelihood evaluation and risk tolerance evaluation.

Our team managed to stay motivated through quick online conference calls combined with file exchange as communication tools.

The analysis of real-life scenarios strengthened both the substance and legitimacy of the research.

What didn't work well:

Several team members conducted duplicate work during initialization by searching for the same cost data.

The team miscalculated how long they would need to develop complete cost-supported recommendations.

The process of verifying real-world sources lasted longer than anticipated and delayed subsequent phases in the task.

Key lessons:

When conducting future projects we will designate section leaders earlier and start developing justifications earlier while implementing visual task management systems through Kanban boards. The establishment of a single research log at project inception would help to enhance the overall efficiency of the work. Although the team faced some small difficulties their effective work resulted in a solid report supported by strong evidence.

INDIVIDUAL REFLECTION:

Being involved in this risk assessment project was intellectually fulfilling and professionally beneficial. From the outset, I approached the task with sincere interest, especially in applying theoretical cybersecurity concepts to practical situations facing an EduTech company like LearnX. This experience pushed me to critically evaluate threat landscapes, asset valuation, and the rationale for employing specific security measures—not only from a technical standpoint but also through financial and organizational perspectives.

During the process, I made noteworthy contributions in both the analysis and documentation stages. I concentrated on risk modelling and identifying appropriate mitigation strategies. One of the most enlightening parts of the project was realizing how even minor oversights—like a misconfigured cloud bucket or a neglected patch cycle—can escalate into significant incidents with serious reputational and financial ramifications. Analysing real-life cases, such as the Illuminate Education breach and Microsoft's SAS token exposure, grounded our decisions in practical relevance rather than relying solely on theoretical concepts.

Time management turned out to be an area of growth. Juggling cost estimations, justifications for controls, and cross-referencing information took longer than I expected. Occasionally, I found myself revising sections of the analysis to better align with spreadsheet logic or to incorporate more reliable citations. Nevertheless, these challenges transformed into valuable learning experiences that deepened my understanding of cybersecurity governance and underscored the necessity for precision in risk communication.

In summary, this experience improved my ability to critically assess security investments, consider cost-benefit trade-offs, and convey risk in a structured and strategic way. It also highlighted the significance of teamwork and role clarity—insights I will take into future collaborative technical projects. This reflection summarizes not only my contributions but also how this exercise has genuinely influenced my perspective as an aspiring cybersecurity professional.

REFERENCES:

TV pair 1:

CanIPhish. (2023, March 30). *How much does security awareness training cost?* CanIPhish.

https://caniphish.com/blog/how-much-does-security-awareness-training-cost

Derrick, J. (2023, April 11). *Nessus vs OpenVAS: Which vulnerability scanner is best?* Comparitech.

https://www.comparitech.com/net-admin/nessus-vs-openvas/

TV pair 2:

Microsoft. (n.d.). *Grant limited access to Azure Storage resources using shared access signatures (SAS)*. Microsoft Learn.

https://learn.microsoft.com/en-us/azure/storage/common/storage-sas-overview

Microsoft. (n.d.). *Microsoft Defender for Cloud pricing*. Azure.
https://azure.microsoft.com/en-us/pricing/details/defender-for-cloud/

KnowBe4. (n.d.). *Security awareness training pricing*.

https://www.knowbe4.com/pricing

TV pair 3:

IBM. (2023). *Cost of a data breach report 2023*. IBM Security.
https://www.ibm.com/reports/data-breach

TV pair 4:

Griffith University. (2017, April 5). *Gold Coast Centre for Coastal Management studies cyclone-ravaged region*. Griffith News.

https://news.griffith.edu.au/2017/04/05/gold-coast-centre-for-coastal-management-studies-cyclone-ravaged-region/

James Cook University – Disaster Management Report (PDF) James Cook University. (n.d.). *Cyclone Yasi impact and recovery report*.
https://www.jcu.edu.au/__data/assets/pdf_file/0009/122859/jcu_078897.pdf